

Отчет о расследовании инцидента безопасности

Подозрительное использование привилегированной учетной записи

Подготовлено для: Руководства ИБ компании Demo Lab
Дата составления: [14.08.2026]
Период инцидента: [20.03.2025. 13:15 - 14:00 UTC]
Статус расследования: [Завершено]

1. Общий обзор инцидента

Краткое описание

20 марта 2025 года в 13:15 UTC зафиксирован успешный вход учётной записи администратора Demo.lab\administrator на сервер APPSERVER (10.0.0.10) с внешнего IP-адреса 45.14.164.3, принадлежащего географическому региону Германия. Вход осуществлён в нерабочее время (03:15 по локальному времени сервера) В течение 25 минут после входа злоумышленник осуществил чтение трёх конфиденциальных файлов из папок Finance, HR и Executive, а затем изменил права доступа к общей папке Finance, установив разрешения Everyone:FullControl. В 14:00 UTC зафиксирован выход из системы. Признаков создания новых учётных записей, закрепления в системе или эксфильтрации данных не обнаружено

Затронутые системы

- **APPSERVER (IP: 10.0.0.10)** - целевой сервер, на котором произошёл несанкционированный вход и выполнялись подозрительные действия
- **Учётная запись Demo.lab\administrator** - скомпрометирована и использована для доступа

2. Хронология инцидента

Время (UTC)	Событие	Источник данных
20.03.2025 13:15:22	Успешный вход administrator с IP 45.14.164.3 (Германия) на APPSERVER (10.0.0.10)	windows_logs_sprint4.ndjson
20.03.2025 13:20:00	Чтение файла \\srv-file\Finance\Confidential\Confidential.docx	windows_logs_sprint4.ndjson
20.03.2025 13:25:00	Чтение файла \\srv-file\HR\Confidential\Confidential.docx	windows_logs_sprint4.ndjson
20.03.2025 13:30:00	Чтение файла \\srv-file\Executive\Strategy\Confidential.docx	windows_logs_sprint4.ndjson
20.03.2025	Изменение прав доступа к папке Finance	windows_logs_sprint4.ndjson

Время (UTC)	Событие	Источник данных
13:40:00	на Everyone: FullControl	
20.03.2025 14:00:00	Выход из системы (UserLogoff)	windows_logs_sprint4.ndjson

3. Технический анализ инцидента

3.1. Вход в систему в нестандартное время

20 марта 2025 года в 13:15 UTC (03:15 по локальному времени сервера) зафиксирован успешный вход учётной записи Demo.lab\administrator на сервер APPSERVER (10.0.0.10) Данный факт указывает на несанкционированный доступ.

3.2. Вход из необычного географического региона

Вход осуществлён с внешнего IP-адреса 45.14.164.3, принадлежащего региону Германия. Географический регион не соответствует рабочей локации сотрудника. Это подтверждает факт компрометации учётной записи.

3.3. Подозрительная активность с файловым хранилищем

В период с 13:20 по 13:30 UTC злоумышленник осуществил чтение следующих конфиденциальных файлов:

\\srv-file\Finance\Confidential\Confidential.docx

\\srv-file\HR\Confidential\Confidential.docx

\\srv-file\Executive\Strategy\Confidential.docx

Данные действия нехарактерны для обычной работы администратора и свидетельствуют о целенаправленном поиске конфиденциальной и чувствительной информации

3.4. Изменение настроек разделяемых ресурсов

В 13:40 UTC зафиксировано событие ShareModify (Event ID 5143), в котором злоумышленник изменил права доступа к общей папке Finance, установив разрешения Everyone: FullControl. Это действие позволяет получить доступ к конфиденциальным данным для всех пользователей домена, что создаёт серьёзную угрозу утечки данных и их целостности.

3.5. Выход из системы

В 14:00 UTC зафиксирован выход из системы (UserLogoff, Event ID 4634) от той же учётной записи. Признаков повторного входа с этого IP-адреса не обнаружено.

4. Индикаторы компрометации (IoC)

IP-адреса

IP-адрес	Страна	Роль	Связанная активность
45.14.164.3	Германия	Злоумышленник под учетной записью администратора	Вход в систему, чтение файлов, изменение прав

Учетные записи

Учетная запись	Система	Действия
Demo.lab\administrator	APPSERVER (10.0.0.10)	Вход, чтение конфиденциальных файлов, изменение прав доступа

Затронутые данные

Ресурс	Тип данных	Потенциальное воздействие
\\srv-file\Finance\Confidential\Confidential.docx	Финансовая отчетность	Вероятная утечка финансовых данных
\\srv-file\HR\Confidential\Confidential.docx	Кадровые данные	Вероятная утечка персональных данных сотрудников
\\srv-file\Executive\Strategy\Confidential.docx	Документы стратегии компании	Вероятная утечка коммерческой тайны
Папка Finance	Права доступа	Изменение прав доступа для всех пользователей

5. Оценка тактик, техник и процедур (TTP)

Initial Access

- **T1078 – Valid Accounts** - Злоумышленник использовал легитимную учетную запись администратора

Defense Evasion

- **T1222 – File and Directory Permissions Modification** - Изменены права доступа к папке Finance на Everyone:FullControl

Collection

- **T1083 – File and Directory Discovery** - Сканирование и чтение файлов в конфиденциальных папках.

6. Исправленные правила корреляции

Правило 1: Обнаружение входов в нерабочее время

Использовалось поле event.action: "LogonTime". Правило срабатывало только на одно известное событие. Заменено на event.code: 4624 для обнаружения всех успешных входов в систему в нерабочее время.

Правило 2: Обнаружение входов из необычного географического региона

Правило было жёстко привязано к учётной записи administrator. Была убрана привязка к конкретной учётной записи, правило теперь должно срабатывать на любых пользователей, входящих из необычных регионов.

Правило 3: Обнаружение подозрительной активности с файлами

Отсутствовало событие ShareModify для обнаружения изменения прав доступа. Добавлено ShareModify в список отслеживаемых действий

Правило 4: Обнаружение изменений в настройках файловых ресурсов

Правило было слишком узким (только event.action: "ShareModify" без маски). Изменено на event.action : *ShareModify* для обнаружения любых вариаций события изменения прав.

7. Выводы и рекомендации

7.1. Общие выводы

В ходе расследования подтверждён факт компрометации учётной записи администратора Demo.lab\administrator. Злоумышленник получил несанкционированный доступ к серверу APPSERVER, осуществил чтение конфиденциальных документов из трёх файлов и изменил права доступа к папке Finance на Everyone: FullControl, что создаёт риск утечки данных и нарушения их целостности. Признаков закрепления в системе не обнаружено, однако оставленные изменения прав требуют немедленного устранения

7.2. Краткосрочные рекомендации

- Немедленно сменить пароль учётной записи administrator и всех привилегированных учётных записей в домене
- Отменить права Everyone:FullControl в папке Finance и восстановить разрешения по принципу минимальных привилегий
- Проверить другие логи, например сетевые логи, логи с агентов EDR, если имеются. Изучить логи за несколько дней до инцидента

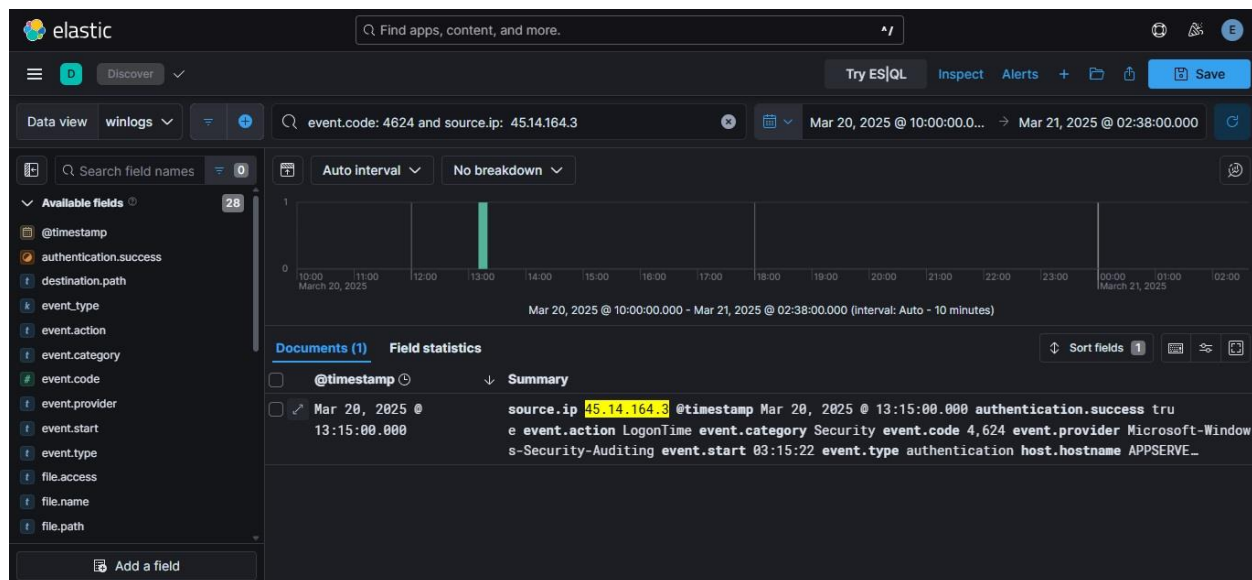
7.3. Среднесрочные рекомендации

- Включить многофакторную аутентификацию для всех административных учётных записей
- Настроить геоблокировку для доступа к критичным серверам и учетным записям, разрешив только страны, где находятся офисы компании и могут работать сотрудники

7.4. Долгосрочные рекомендации

- Внедрить систему мониторинга для обнаружения аномальных входов (нестандартное время, необычные геолокации)
- Пересмотреть политику управления учётными записями, включая регулярную смену паролей
- Обновить правила корреляции на основе выявленных индикаторов для автоматического обнаружения подобных атак в будущем

8. Приложения



Documents (31)Field statistics

Sort fields1

☐	@timestamp	Summary
☒	Mar 20, 2025 @ 14:24:00.000	host.ip 10.0.0.10 user.name administrator @timestamp Mar 20, 2025 @ 14:24:00.000 event.action UserLogon event.category Security event.code 4,625 event.provider Microsoft-Windows-Security-Auditing event.type file host.hostname WIN-F9E0CCA1 host.os.name Windows Server 2019 source.ip 10.0.0.10 user.domain Demo.lab _id Y1EY4p88AlaxhaWd15vr _ignored - _index winlogs _score -
☒	Mar 20, 2025 @ 14:00:00.000	host.ip 10.0.0.10 user.name administrator @timestamp Mar 20, 2025 @ 14:00:00.000 event.action UserLogoff event.category Security event.code 4,634 event.provider Microsoft-Windows-Security-Auditing event.type authentication host.hostname APPSERVER host.os.name Windows Server 2019 source.ip 45.14.164.3 user.domain Demo.lab _id 4VEY4p88AlaxhaWd15vr _ignored - _index winlogs _score -
☒	Mar 20, 2025 @ 13:40:00.000	host.ip 10.0.0.10 user.name administrator @timestamp Mar 20, 2025 @ 13:40:00.000 event.action ShareModify event.category Security event.code 5,143 event.provider Microsoft-Windows-Security-Auditing event.type file file.share_name Finance file.share_path C:\Shares\Finance file.share_permissions Everyone:FullControl host.hostname APPSERVER host.os.name Windows Server 2019 source.ip 45.14.164.3 user.domain Demo.lab _id 3FEY4p88AlaxhaWd15vr _ignored - _index winlogs _score -
☒	Mar 20, 2025 @ 13:30:00.000	host.ip 10.0.0.10 user.name administrator @timestamp Mar 20, 2025 @ 13:30:00.000 event.action FileAccess event.category Security event.code 4,625 event.provider Microsoft-Windows-Security-Auditing event.type process host.hostname WIN-A997ABE0 host.os.name Windows Server 2019 source.ip 10.0.0.10 user.domain Demo.lab _id SFEY4p88AlaxhaWd15vr _ignored - _index winlogs _score -
☒	Mar 20, 2025 @ 13:30:00.000	host.ip 10.0.0.10 user.name administrator @timestamp Mar 20, 2025 @ 13:30:00.000 event.action FileAccess event.category Security event.code 5,140 event.provider Microsoft-Windows-Security-Auditing event.type file file.access ReadData file.path \\srv-file\Executive\Strategy\Confidential.doc x file.share_name Confidential host.hostname APPSERVER host.os.name Windows Server 2019 source.ip 45.14.164.3 user.domain Demo.lab _id 31EY4p88AlaxhaWd15vr _ignored - _index winlogs _score -
☒	Mar 20, 2025 @ 13:25:00.000	host.ip 10.0.0.10 user.name administrator @timestamp Mar 20, 2025 @ 13:25:00.000 event.action FileAccess event.category Security event.code 4,663 event.provider Microsoft-Windows-Security-Auditing event.type file file.access ReadData file.path \\srv-file\HR\Confidential\Confidential.doc x file.share_name Confidential host.hostname APPSERVER host.os.name Windows Server 2019 source.ip 45.14.164.3 user.domain Demo.lab _id 31EY4p88AlaxhaWd15vr _ignored - _index winlogs _score -
☒	Mar 20, 2025 @ 13:20:00.000	host.ip 10.0.0.10 user.name administrator @timestamp Mar 20, 2025 @ 13:20:00.000 event.action FileAccess event.category Security event.code 4,663 event.provider Microsoft-Windows-Security-Auditing event.type file file.access ReadData file.path \\srv-file\Finance\Confidential\Confidential.doc x file.share_name Confidential host.hostname APPSERVER host.os.name Windows Server 2019 source.ip 45.14.164.3 user.domain Demo.lab _id 31EY4p88AlaxhaWd15vr _ignored - _index winlogs _score -
☒	Mar 20, 2025 @ 13:15:00.000	host.ip 10.0.0.10 user.name administrator @timestamp Mar 20, 2025 @ 13:15:00.000 authentication.success true event.action LogonTime event.category Security event.code 4,624 event.provider Microsoft-Windows-Security-Auditing event.start 03:15:22 event.type authentication host.hostname APPSERVER host.os.name Windows Server 2019 source.geo.country_name Germany source.ip 45.14.164.3 user.domain Demo.lab _id 3FEY4p88AlaxhaWd15vr _ignored - _index winlogs _score -

Rows per page: 100

Скриншоты исправленных правил корреляции

elastic

Find apps, content, and more.

AI Assistant

Security Rules Detection rules (SIE...) Обнаружение вход... Alerts

ML job settings Add integrations Data view Alerts

Security

Dashboards

Rules

Alerts

Attack discovery

Findings

Cases

Timelines

Intelligence

Explore

Get started

Manage

Filter your data using KQL syntax

Today Refresh

Правило обнаруживает входы в систему в нерабочее время (с 22:00 до 6:00).

Severity

Risk score

Max alerts per run

Medium

60

100

Index patterns

Custom query

Custom query language

Rule type

Required fields

Timeline template

file: winlogs

hostip: "10.0.0.10" AND event.code: 4624 AND (event.start: "00:*:*" OR event.start: "01:*:*" OR event.start: "02:*:*" OR event.start: "03:*:*" OR event.start: "04:*:*" OR event.start: "05:*:*" OR event.start: "22:*:*" OR event.start: "23:*:*")

KQL

Query

host.ip, event.action, event.start, user.name, source.ip, event.code

None

Untitled timeline Unsaved

elastic

Find apps, content, and more.

AI Assistant

SecurityRulesDetection rules (SIE...Обнаружение вход...Alerts

ML job settingsAdd integrationsData viewAlerts

Security

DashboardsRulesAlertsAttack discoveryFindingsCasesTimelinesIntelligenceExploreGet startedManage

Filter your data using KQL syntax

Today

About

Правило обнаруживает входы в систему из географических регионов, не входящих в белый список разрешенных стран.

SeverityLow

Risk score21

Max alerts per run100

Definition

Index patternswinlogs

Custom queryhost.ip : "10.0.0.10" AND source.geo.country_name : * AND NOT source.geo.country_name : ("Russia" OR "United States" OR "United Kingdom" OR "Canada")

Custom query languageKQL

Rule typeQuery

Required fields

host.ip, user.name, source.geo.country_name, source.ip

Untitled timelineUnsaved

elastic

Find apps, content, and more.

AI Assistant

SecurityRulesDetection rules (SIE...Обнаружение ного...Alerts

ML job settingsAdd integrationsData viewAlerts

Security

DashboardsRulesAlertsAttack discoveryFindingsCasesTimelinesIntelligenceExploreGet startedManage

Filter your data using KQL syntax

TodayRefresh

About

Правило обнаруживает аномальный доступ к конфиденциальным разделам файлового хранилища.

SeverityHigh

Risk score73

Max alerts per run100

Definition

Index patternswinlogs

Custom queryhost.ip : "10.0.0.10" AND event.action : (*FileShare* OR *ShareModify* OR *FileModify* OR *FileAccess* OR *FileCreate* OR *FileDelete*)

Custom query languageKQL

Rule typeThreshold

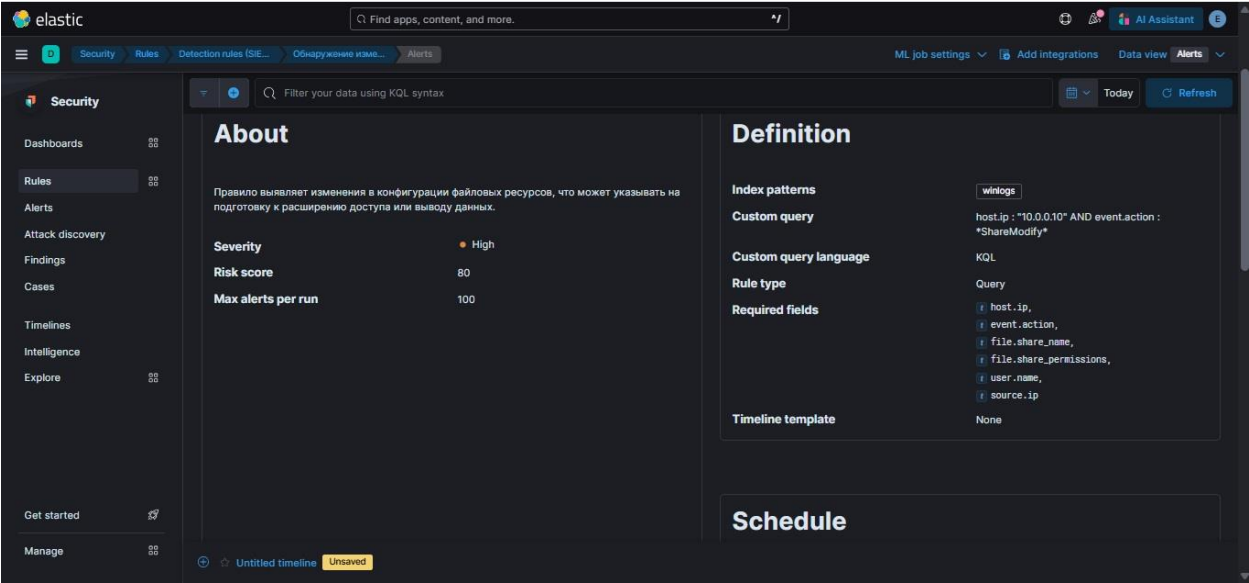
Required fields

host.ip, event.action, file.name, file.share_name, user.name, source.ip

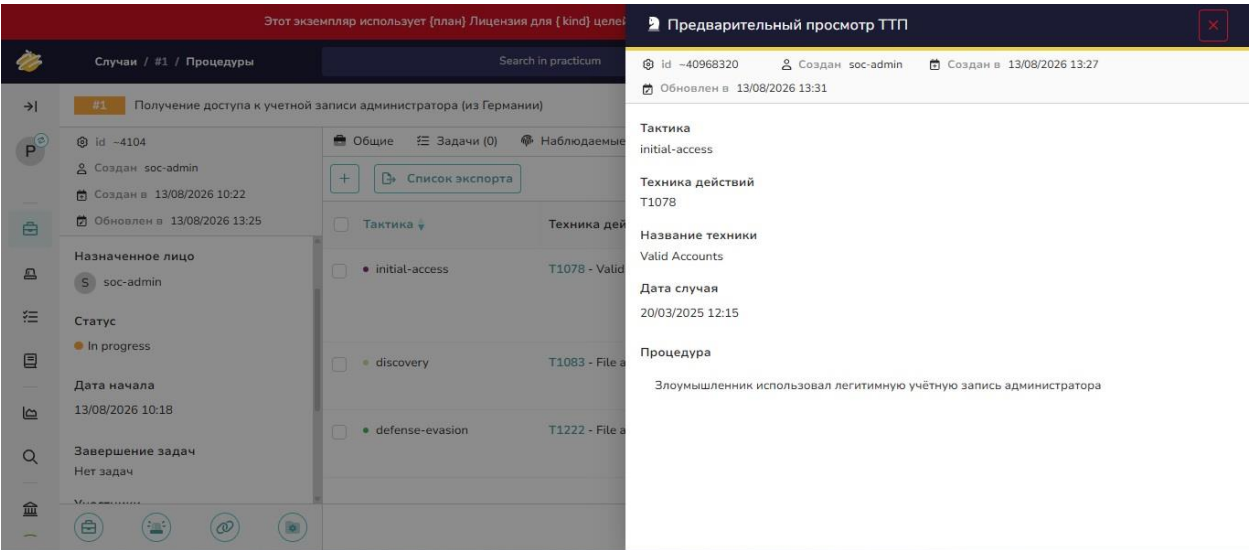
Timeline templateNone

ThresholdResults aggregated by user.name.keyword,source.ip.keyword >= 5

Untitled timelineUnsaved



Скриншоты кейса The Hive



Этот экземпляр использует (план) Лицензия для { kind} целей

Предварительный просмотр ТТП

Случаи / #1 / Процедуры

Search in practicum

id -40964176

Создан soc-admin

Создан в 13/08/2026 13:35

Получение доступа к учетной записи администратора (из Германии)

id -4104

Создан soc-admin

Создан в 13/08/2026 10:22

Обновлен в 13/08/2026 13:25

Назначенное лицо

soc-admin

Статус

In progress

Дата начала

13/08/2026 10:18

Завершение задач

Нет задач

Общие

Задачи (0)

Наблюдаемые

Список экспорта

Тактика

Техника действий

initial-access

T1078 - Valid

discovery

T1083 - File a

defense-evasion

T1222 - File a

Тактика

discovery

Техника действий

T1083

Название техники

File and Directory Discovery

Дата случая

20/03/2025 13:20

Процедура

Чтение файлов в конфиденциальных папках

Этот экземпляр использует (план) Лицензия для { kind} целей

Предварительный просмотр ТТП

Случаи / #1 / Процедуры

Search in practicum

id -81928208

Создан soc-admin

Создан в 13/08/2026 13:40

Получение доступа к учетной записи администратора (из Германии)

id -4104

Создан soc-admin

Создан в 13/08/2026 10:22

Обновлен в 13/08/2026 13:25

Назначенное лицо

soc-admin

Статус

In progress

Дата начала

13/08/2026 10:18

Завершение задач

Нет задач

Общие

Задачи (0)

Наблюдаемые

Список экспорта

Тактика

Техника действий

initial-access

T1078 - Valid

discovery

T1083 - File a

defense-evasion

T1222 - File a

Тактика

defense-evasion

Техника действий

T1222

Название техники

File and Directory Permissions Modification

Дата случая

20/03/2025 13:40

Процедура

Изменение прав на папку Finance на Everyone:FullControl

Отчет подготовил: [Егоров Николай Анатольевич]
Дата составления: [14.08.2026]

Исправленный плейбук

Плейбук реагирования на подозрительное использование учетной записи

Описание инцидента

Данный плейбук предназначен для реагирования на инциденты, связанные с подозрительным использованием привилегированных учетных записей, в том числе входом в нестандартное время, из необычного географического региона и выполнением нехарактерных действий.

Процедура реагирования

Стадия 1: Первоначальная оценка и проверка (0-10 минут)

Шаг 1: Подтверждение инцидента

1. Проверить детали алерта в SIEM
2. Определить, связан ли алерт с запланированными работами или известной активностью
3. Не использовать пороговые значения как единственный критерий для закрытия инцидента. Необходимо проводить контекстный анализ каждого события, если имеются подозрения
4. При любых сомнениях назначить дополнительную проверку логов. Также при необходимости запросить дополнительные логи, если такие имеются. Запросить подтверждение владельца учетной записи. Если инцидент подтверждается – эскалировать его на аналитиков второй линии L2

Шаг 2: Проверка контекста

1. Если время входа нестандартное, проверить график работы пользователя
2. Если местоположение необычное, проверить:
 - Командировки сотрудника
 - Использование VPN
 - Запросить у сотрудника подтверждение входа в систему

Стадия 2: Анализ и оценка риска (10-30 минут)

Шаг 1: Анализ временной шкалы

1. Собрать временную шкалу активности учетной записи за последние 24 часа
2. Определить, какие действия были выполнены после входа

Шаг 2: Оценка активности с файловым хранилищем

1. Проверить изменения в настройках файловых ресурсов
2. Проверить, какие файлы были открыты, изменены или удалены

Шаг 3: Определение категории риска

1. Классифицировать инцидент по уровню риска (низкий/средний/высокий):

- Низкий: единичный вход в нерабочее время из известного региона
- Средний: множественные входы или доступ к нестандартным файлам
- Высокий: доступ из неизвестного региона с изменением конфигураций конфиденциальных чувствительных файлов

Стадия 3: Сдерживание и реагирование (30-60 минут)

Шаг 1: Дополнительная проверка

1. Запросить у пользователя подтверждение легитимности действий через заранее согласованный канал связи, отвечающий политикам безопасности компании. Как запасной вариант можно использовать телефонный звонок, личный мессенджер, внутренний чат. Не использовать корпоративную почту, т.к. она также может быть скомпрометирована
2. В открытом виде не передавать пароли и чувствительную информацию по непроверенным каналам связи
3. Если пользователь подтверждает действия, закрыть инцидент как ложное срабатывание

Шаг 2: Реагирование на подтвержденный инцидент

1. Если действия не подтверждены пользователем или отсутствует ответ, заблокировать учетную запись, создать инцидент и эскалировать его на аналитика второй линии L2
2. Проверить другие активные сессии пользователя
3. Принудительно завершить сессии

Стадия 4: Расследование (1-4 часа)

Шаг 1: Глубокий анализ активности

1. Изолировать затронутые системы от сети, чтобы не допустить дальнейшего распространения атаки на другие машины внутри сети
2. При возможности сохранить логи, дампы памяти и образы дисков в защищенное хранилище для дальнейшего расследования командой криминалистов
3. Проверить связанные IP-адреса

Шаг 2: Анализ воздействия

1. Определить, какие данные были прочитаны, изменены или скопированы
2. Оценить критичность затронутых данных

Шаг 3: Проверка на индикаторы компрометации

1. Проверить наличие новых или измененных учетных записей
2. Проверить изменения в групповых политиках
3. Сканировать систему на наличие вредоносного ПО

Стадия 5: Восстановление (4-24 часа)

Шаг 1: Сброс учетных данных

1. Сменить пароль учётной записи на новый сложный пароль. Передать новый пароль пользователю только после подтверждения его личности через защищённый канал связи
2. Убедиться, что временная блокировка учетной записи снята

Шаг 2: Проверка изменений

1. Проверить и откатить неавторизованные изменения файловых разрешений, сравнить с эталонной конфигурацией
2. Восстановить конфигурацию файлового сервера

Шаг 3: Заключительное сканирование

1. Провести полное сканирование системы
2. Проверить логи на предмет остаточной подозрительной активности

Стадия 6: Извлечение уроков и улучшение (после инцидента)

Шаг 1: Анализ инцидента

1. Команде криминалистов необходимо совместно с L3 аналитиками провести полный и подробный анализ произошедшего. Понять мотивы злоумышленника и восстановить хронологию событий. Найденные уязвимости задокументировать и разработать план действия для недопустимости их повторения
2. Провести ретроспективный анализ инцидента

Шаг 2: Улучшение контроля

1. Обновить белый список разрешенных стран
2. Настроить многофакторную аутентификацию для привилегированных учетных записей

Шаг 3: Обновление плейбука и правил

1. Обновить пороговые значения в правилах корреляции, основываясь на произошедшем инциденте. Обновить и улучшить правила корреляции для выявления и недопустимости повторения подобных атак
2. Усовершенствовать процедуры реагирования
3. Проверить и проанализировать смежные системы на наличие следов компрометации и возможного распространения злоумышленника внутри корпоративной сети